Stride Security Reference Architecture

Version 7.0

Enterprise Trust Security Reference Architecture

Stride — K12 Inc.

Incorporating:

22 D2 Architecture Diagrams (Landscape-Optimized)
Per-Section NIST CSF 2.0 Cross-References
FERPA and SOX §404 Regulatory Alignment

Document Date: March 2, 2026
Classification: Confidential

Supersedes: SRA V6 (February 27, 2026)

Contents

Diagram Legend and Conventions 2

1 Executive Summary 3

2 Trust Security Architecture Overview 5

3 Personas and Trust Boundaries 7

4 Identity and Access Architecture 9

5 Privileged Trust (Delinea and Entra PIM) 14

6 Device Trust (CrowdStrike and Defender) 15

7 Exposure and Posture (Tenable VM and CSPM) 16

8 Application and API Trust (Sonatype, Burp Suite, Salt) 17

9 Operational Trust (ServiceNow SecOps, CMDB, Tagging) 18

10 NIST CSF 2.0 Outcome Mapping 20

11 Implementation Roadmap 21

12 Key Performance Indicators (KPIs) 22

13 Regulatory Compliance Alignment (SOX, FERPA) 23

A APPENDIX A — Acronyms and Definitions 25

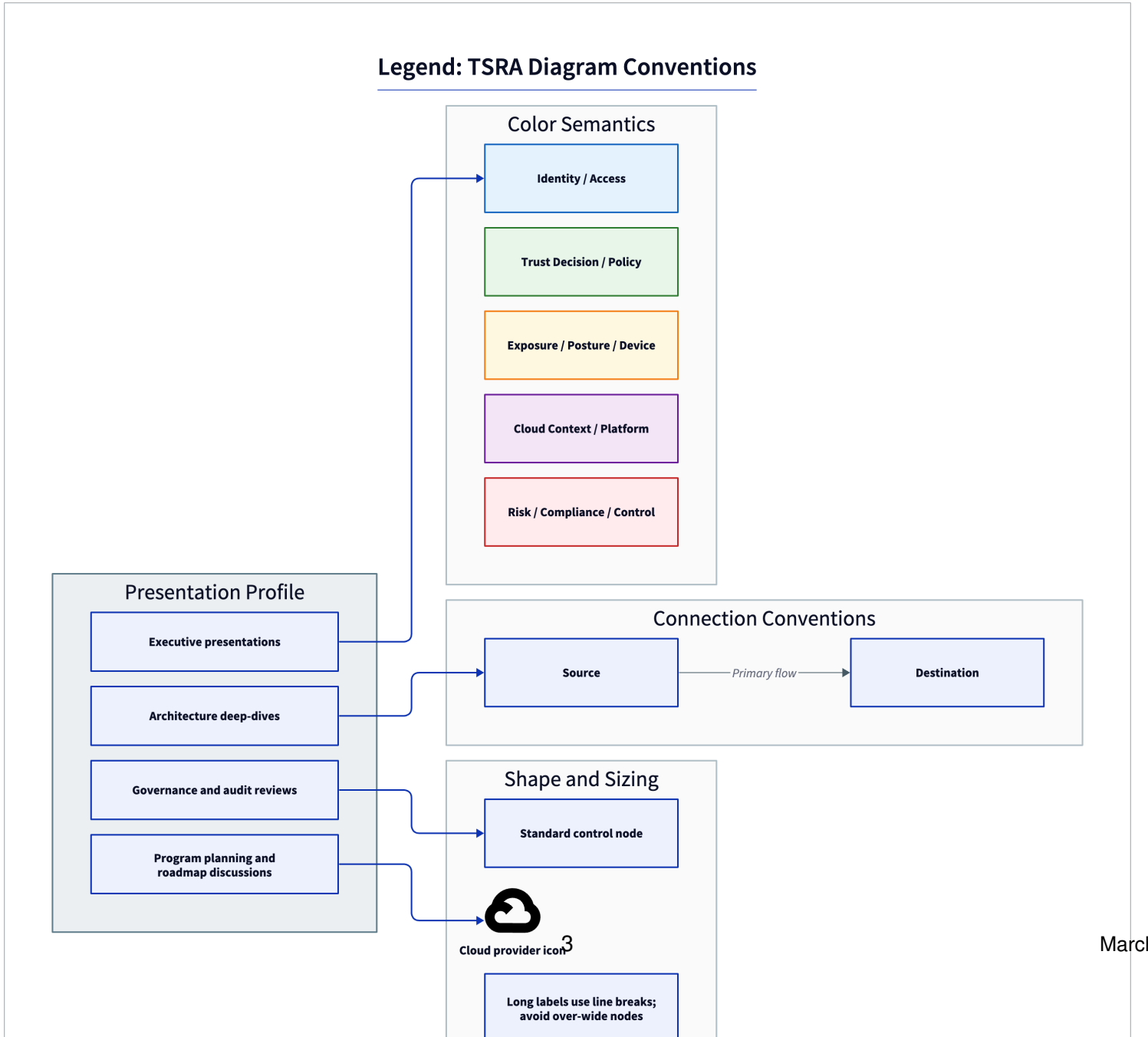
B APPENDIX B — Document Control 28

C APPENDIX C — NIST CSF 2.0 Mapping and Implementation Status 30

D APPENDIX D — Evidence Traceability Matrix 32

E APPENDIX E — Consolidated Gap Register 33

Diagram Legend and Conventions



1 Executive Summary

NIST CSF 2.0 Alignment: GV.OC-01, GV.RM-01, GV.OV-01

This Enterprise Trust Security Reference Architecture (TSRA) defines how Stride establishes, evaluates, enforces, degrades, and restores trust across identities, devices, workloads, APIs, data, and operations for cloud-native education technology platforms serving staff, students, and customers.

The architecture uses NIST CSF 2.0 as the primary outcomes framework and aligns to NIST SP 800-207 principles. It integrates current and planned security capabilities into a coherent model that is actionable, auditable, and resilient to tool changes, while remaining explicit about enforcement points and evidence sources.

- Implement trust principles across all personas with identity-centric, risk-adaptive controls.
- Establish unified identity governance via SailPoint for provisioning, deprovisioning, access certification, and SoD.
- Protect privileged access using Delinea for vaulting, rotation, and session control; mature privileged role governance with Entra PIM (future).
- Maintain high-confidence device trust using CrowdStrike Falcon as the primary enforcement signal with Defender for Endpoint telemetry in monitor mode.
- Continuously assess exposure using Tenable VM for vulnerability management and Tenable.cs for CSPM posture and drift.
- Secure SDLC and supply-chain risk with Sonatype SCA, validate runtime security using Burp Suite DAST, and mature API security with Salt (future).
- Centralize operational trust and evidence via ServiceNow SecOps; mature CMDB and cloud tagging for ownership and criticality (future).
- Meet SOX and FERPA obligations with measurable controls and auditable evidence trails.

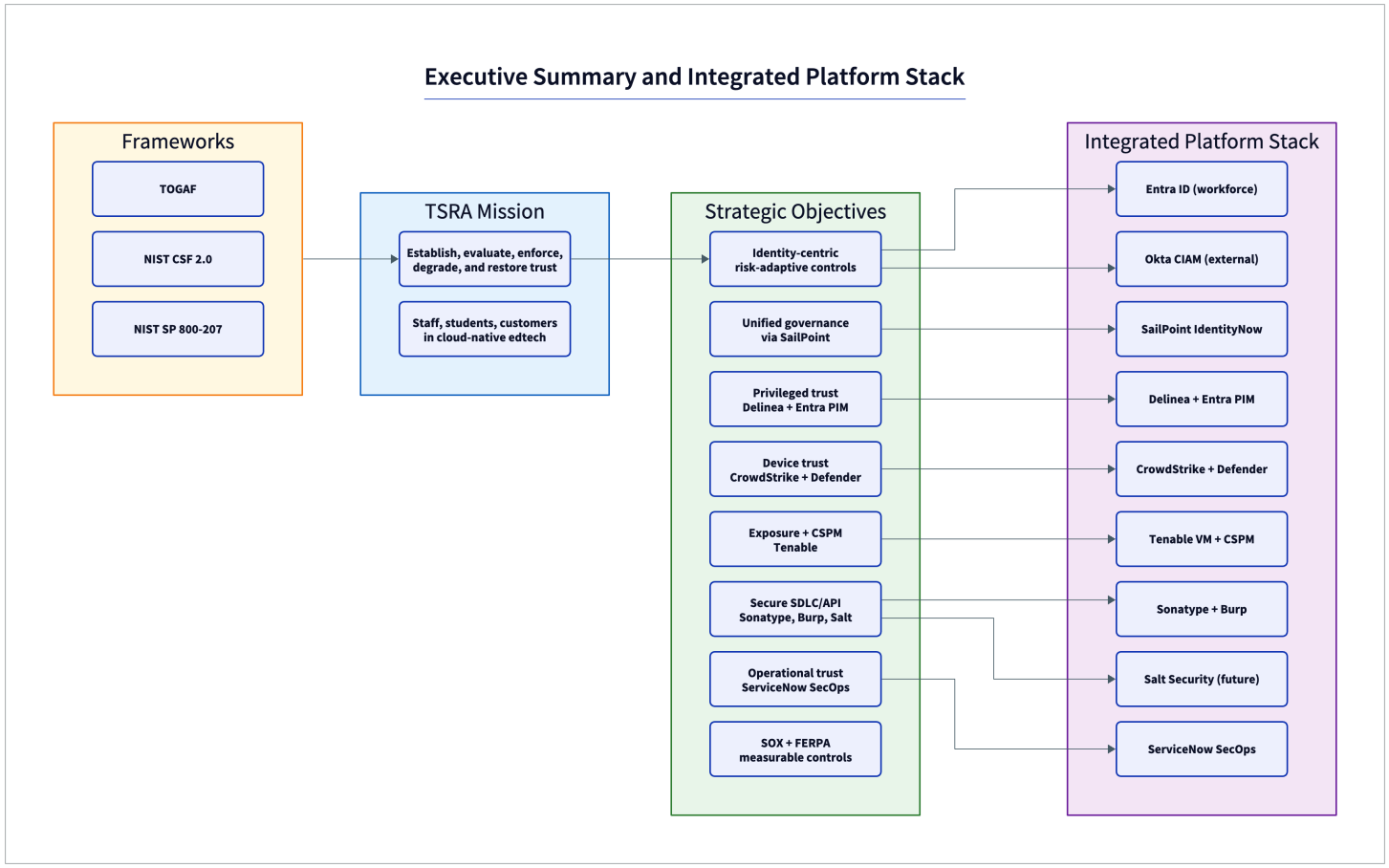


Figure 1: 16 Executive Summary And Platform Stack

2 Trust Security Architecture Overview

NIST CSF 2.0 Alignment: GV.PO-01, PR.AA-01, PR.PS-01

The TSRA implements the principle of 'never trust, always verify' as a continuous trust computation model. Trust is non-binary and time-bound: it is established with evidence, degraded when risk increases, and restored only after validation.

Zero Trust focuses on access decisioning. Trust Architecture extends this by governing the confidence required for specific actions over time, including data actions (view/export), privileged elevations, and API behaviors.

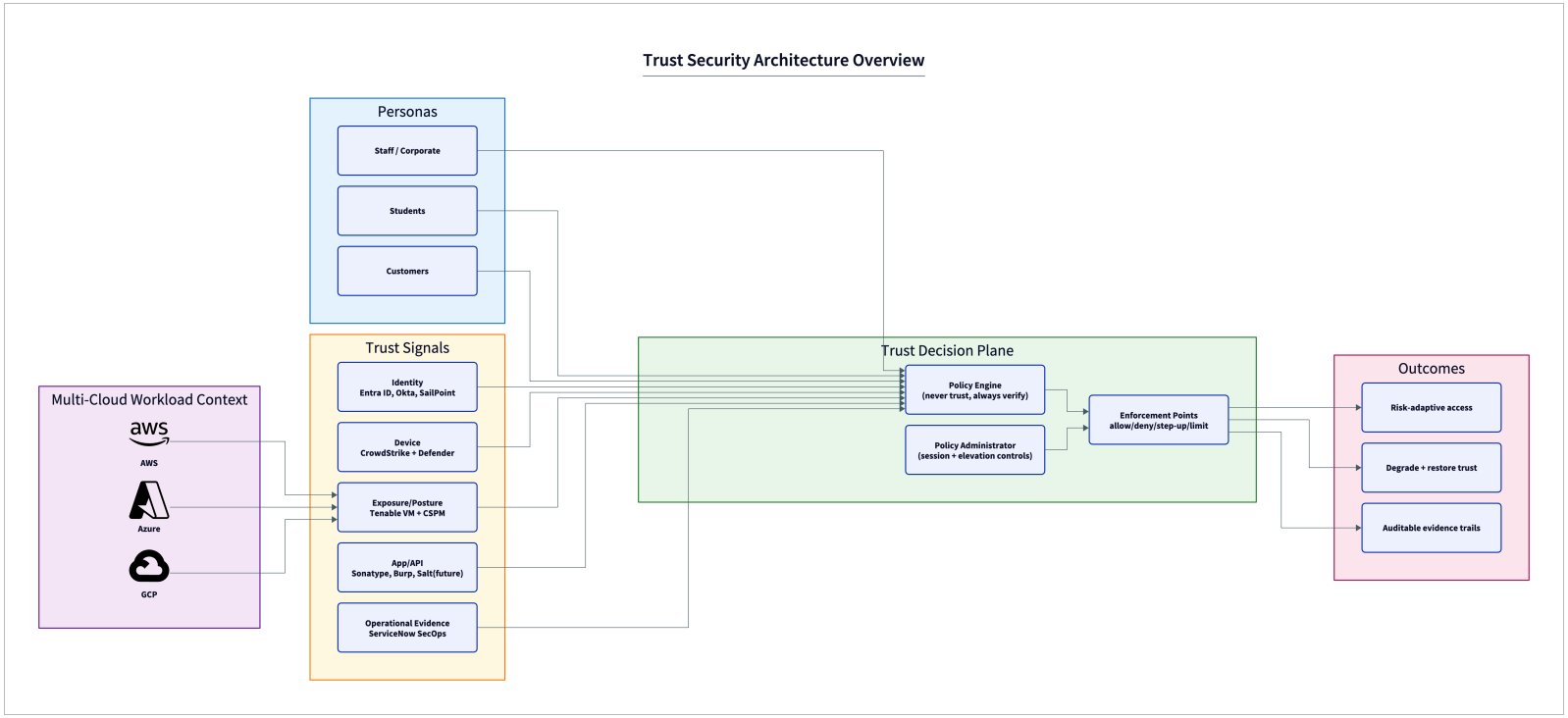


Figure 2: 01 Trust Security Architecture Overview

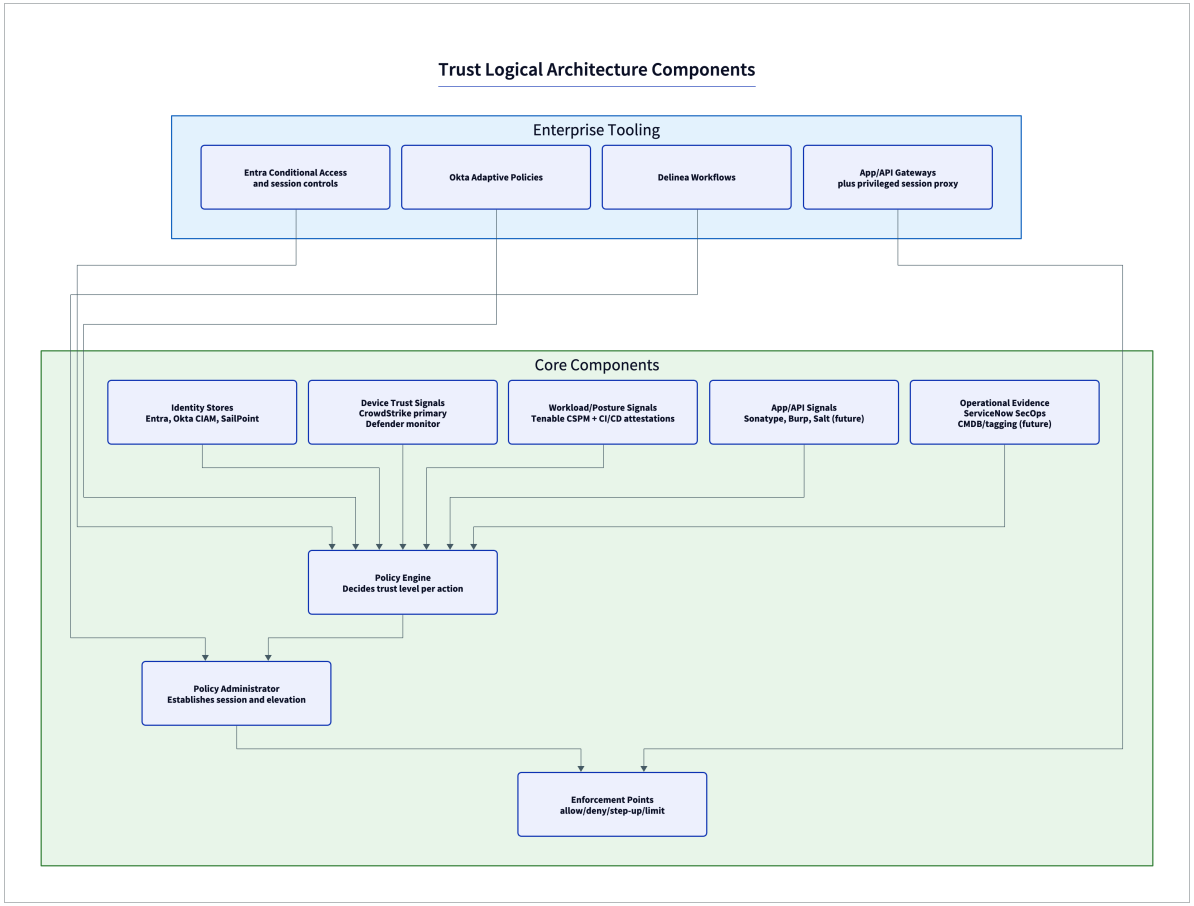


Figure 3: 02 Trust Logical Architecture Components

3 Personas and Trust Boundaries

NIST CSF 2.0 Alignment: PR.AA-01, PR.AA-03, ID.AM-01

- Stride serves three primary user populations with differentiated identity, session requirements, and trust assumptions.
- Staff are the highest-risk population due to access to sensitive data, administrative systems, and infrastructure.
- Students represent the largest population. Access is governed through Okta CIAM with lifecycle driven by SIS via SailPoint. Trust is primarily contextual and behavioral due to unmanaged endpoints.
- Customers (parents/guardians) use self-service registration with verification. Step-up trust is required for payments and PII access.

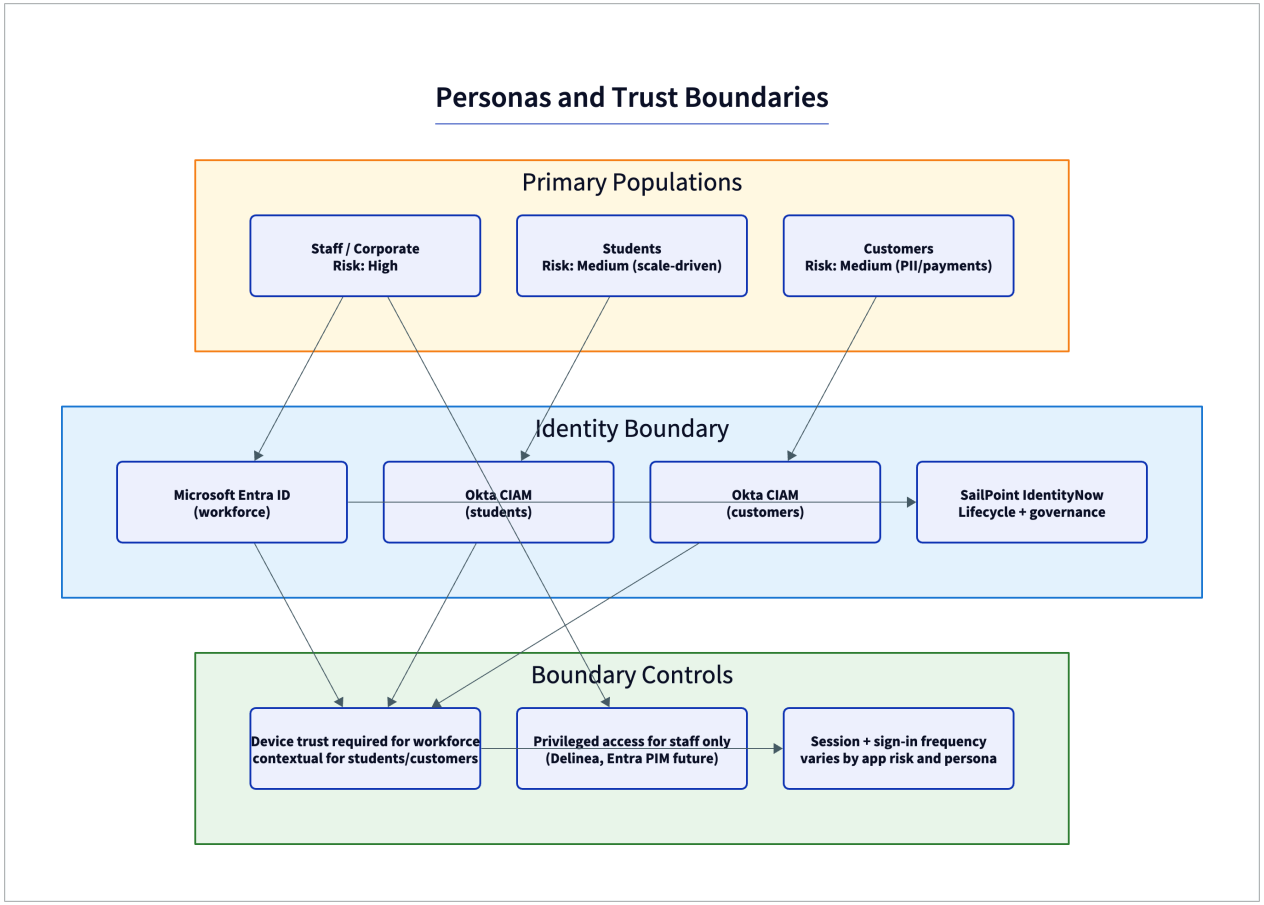


Figure 4: 03 Persona Trust Boundaries

4 Identity and Access Architecture

NIST CSF 2.0 Alignment: PR.AA-01, PR.AA-02, PR.PS-01

FERPA Relevance: FERPA §99.31 (consent exceptions for legitimate educational interest) and §99.32 (disclosure records) require identity controls that enforce role-based access aligned with educational purpose.

SOX §404 Relevance: SOX §404 AC-1 through AC-5: logical access provisioning, periodic reviews, PAM, MFA, and service account controls directly implement IAM architecture requirements.

Gap — FERPA Consent and Disclosure Controls: §99.30 (consent for disclosures) and §99.35 (access by state/local officials) lack explicit architectural controls for consent management and disclosure tracking beyond role-based access. NIST CSF PR.AA-04 (identity assertions managed) and PR.AA-06 (access rights managed) are not addressed in the current SRA subcategory mapping. A formal consent-management workflow and disclosure-audit mechanism should be established within the SailPoint/Entra governance layer.

The identity architecture is hybrid: Entra ID is authoritative for workforce identities and Okta CIAM is authoritative for external identities. SailPoint provides unified governance and attestation across both.

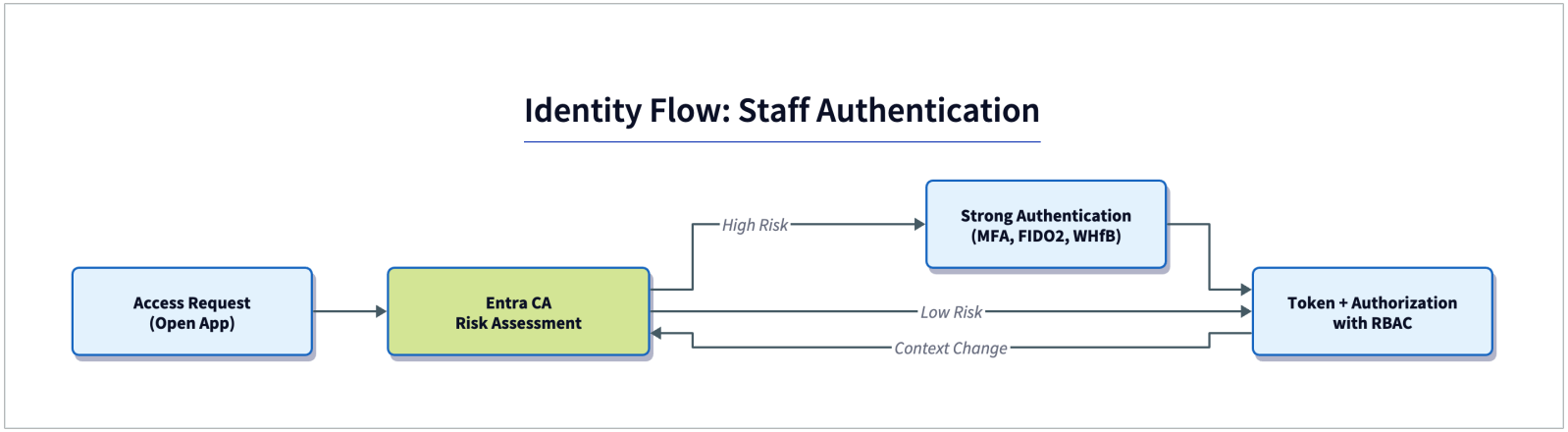


Figure 5: 04 Staff Authentication Flow

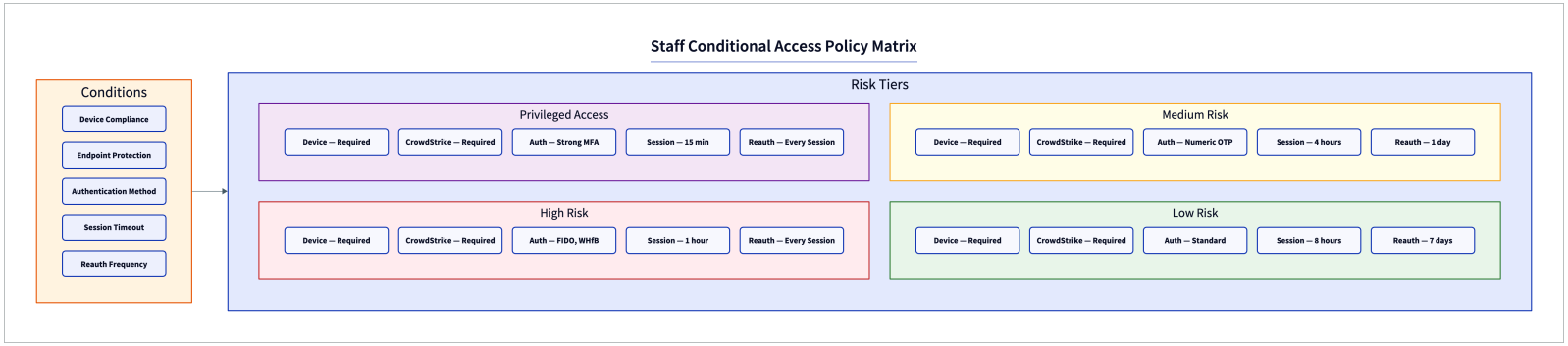


Figure 6: 05 Staff Conditional Access Policy Matrix

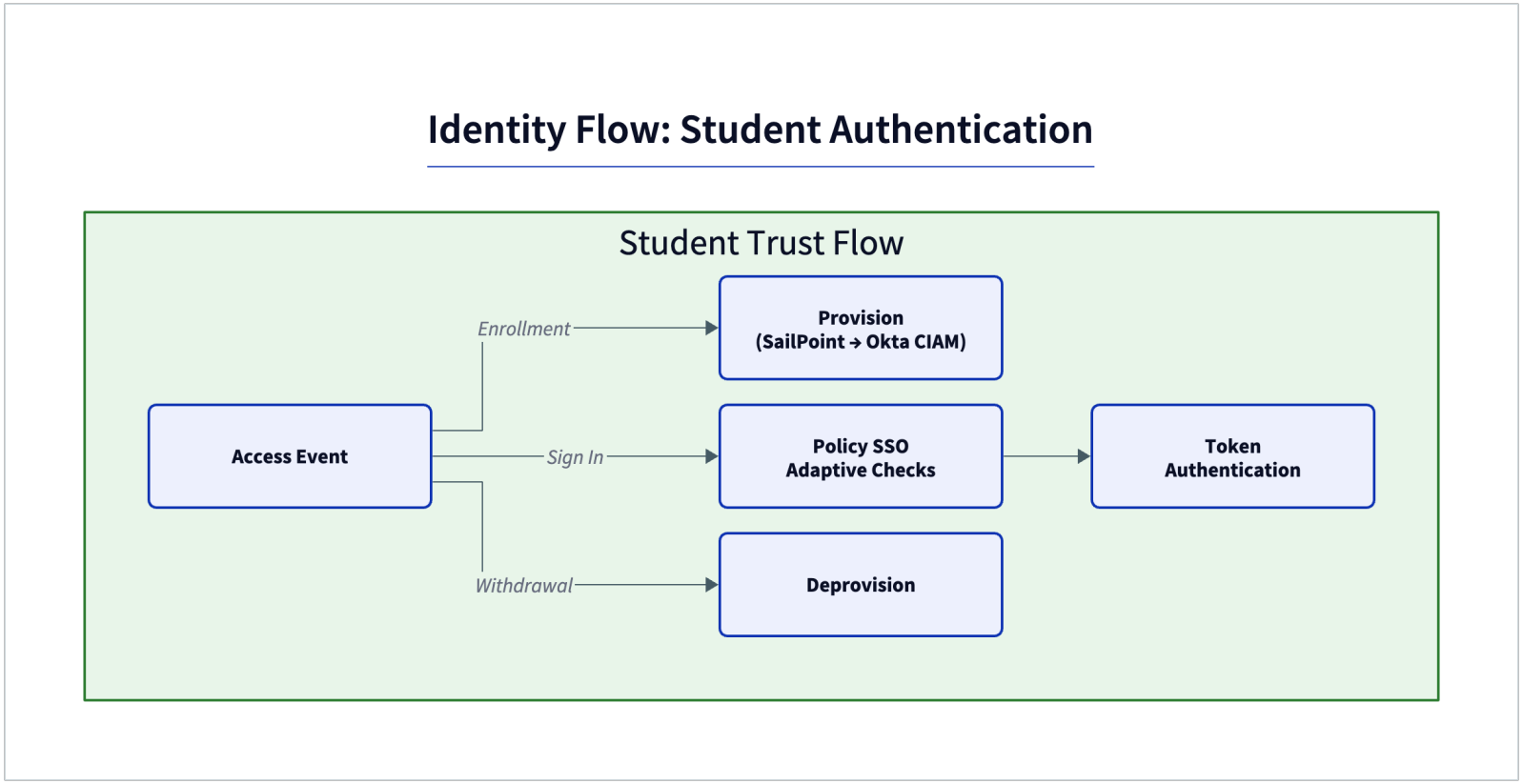


Figure 7: 06 Student Authentication Flow

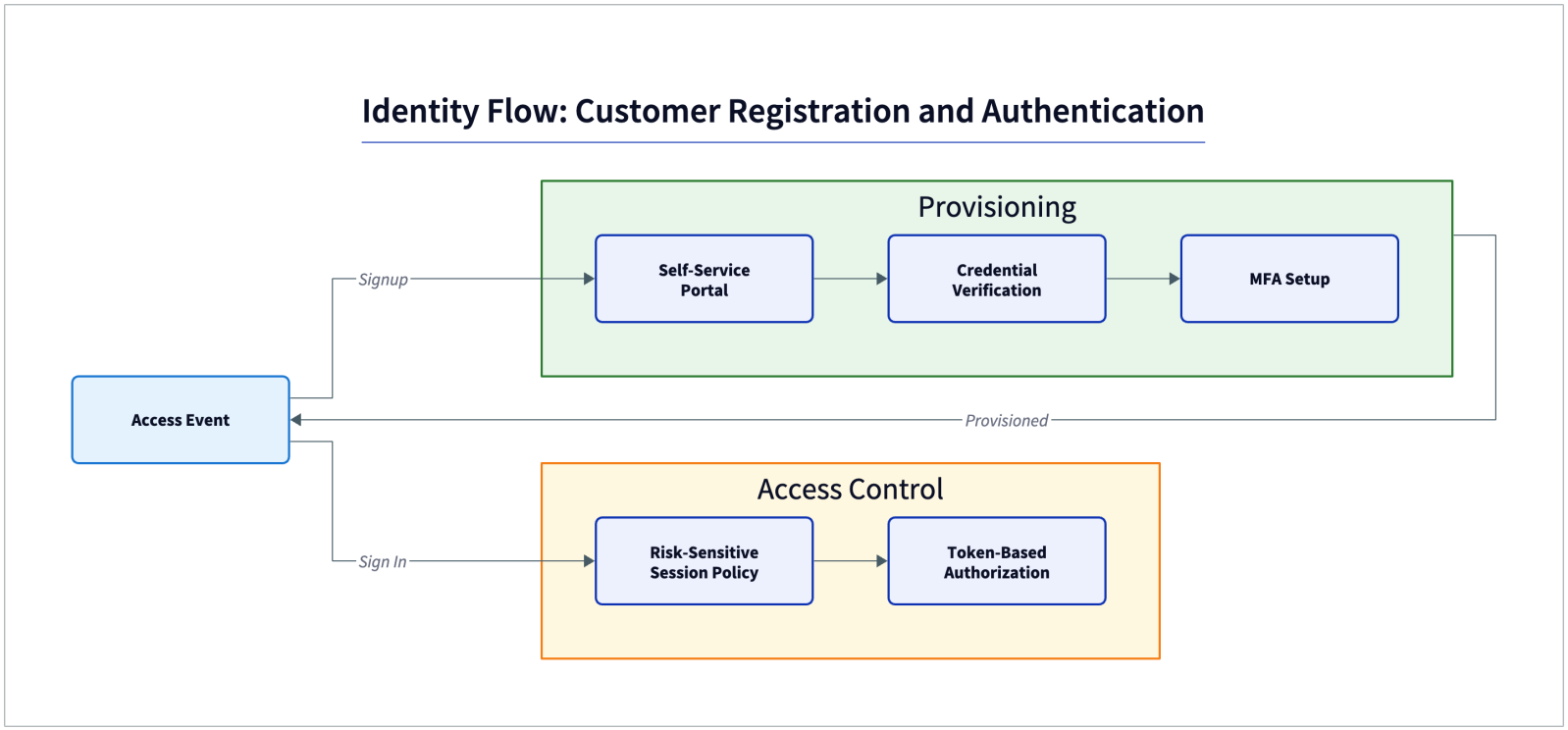


Figure 8: 07 Customer Authentication Flow

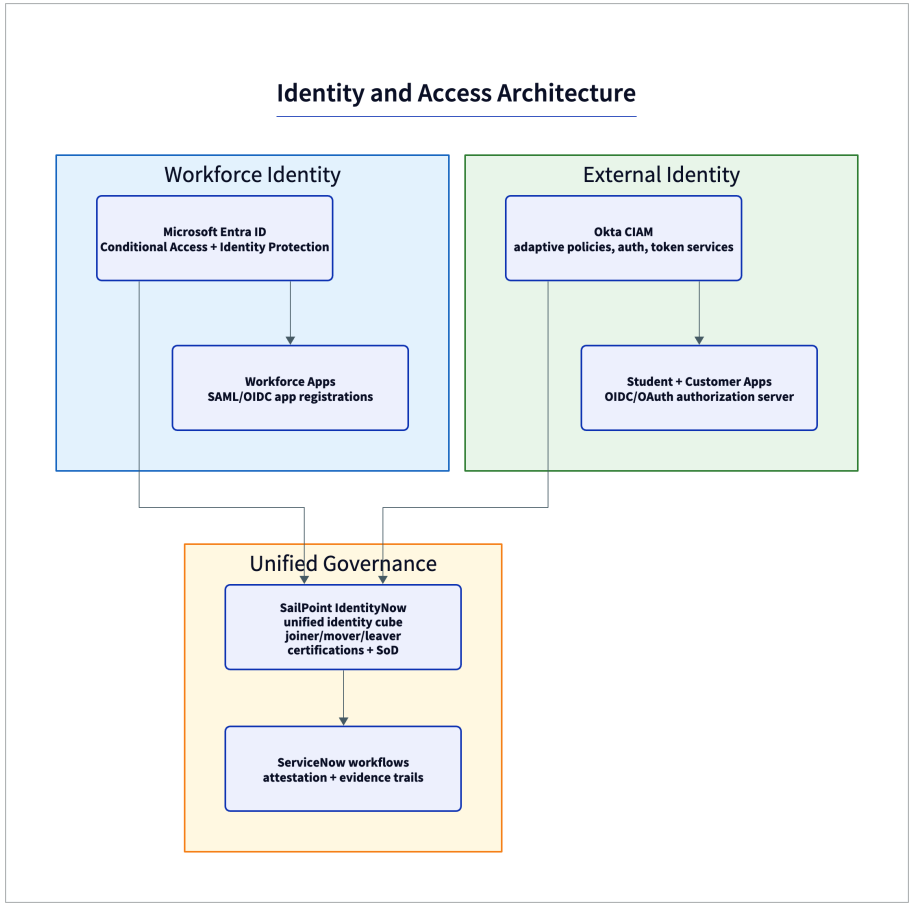


Figure 9: 08 Identity And Access Architecture

5 Privileged Trust (Delinea and Entra PIM)

NIST CSF 2.0 Alignment: PR.AA-05, PR.PS-02, DE.CM-03

SOX §404 Relevance: SOX §404 AC-3: privileged access management with JIT elevation and session recording.

Privileged access is controlled through Delinea for credential vaulting, rotation, and session control for privileged accounts, with Entra PIM planned to mature privileged role governance for Entra roles.

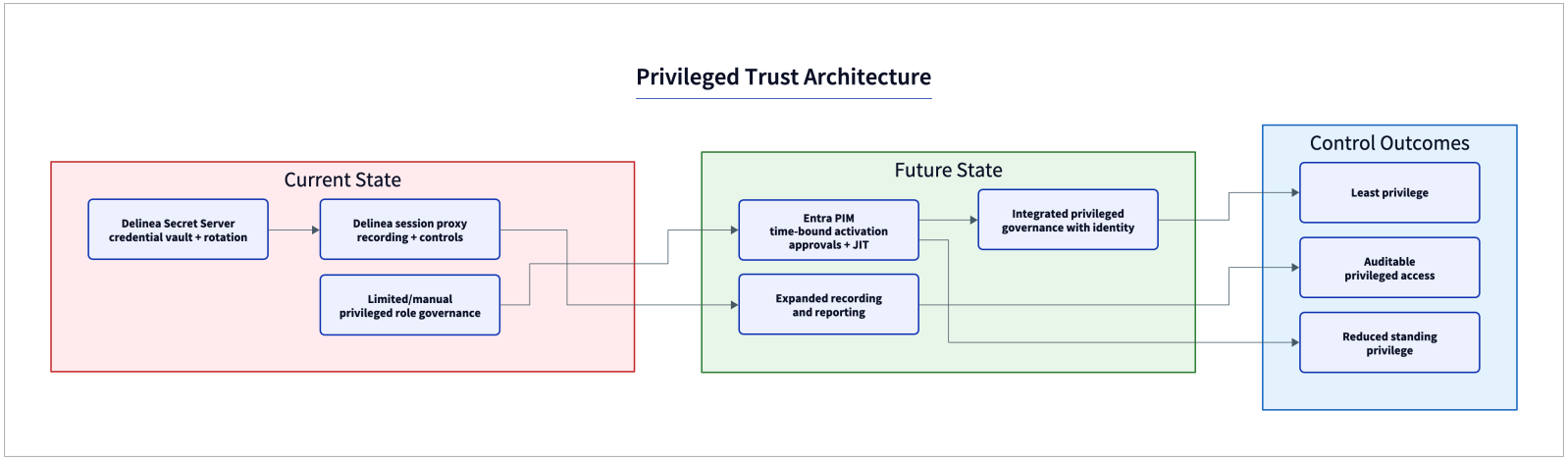


Figure 10: 09 Privileged Trust Architecture

6 Device Trust (CrowdStrike and Defender)

NIST CSF 2.0 Alignment: PR.PS-03, DE.CM-01

- CrowdStrike Falcon provides primary endpoint protection and device trust signals. Microsoft Defender for Endpoint is deployed in monitor mode to provide supplemental telemetry.

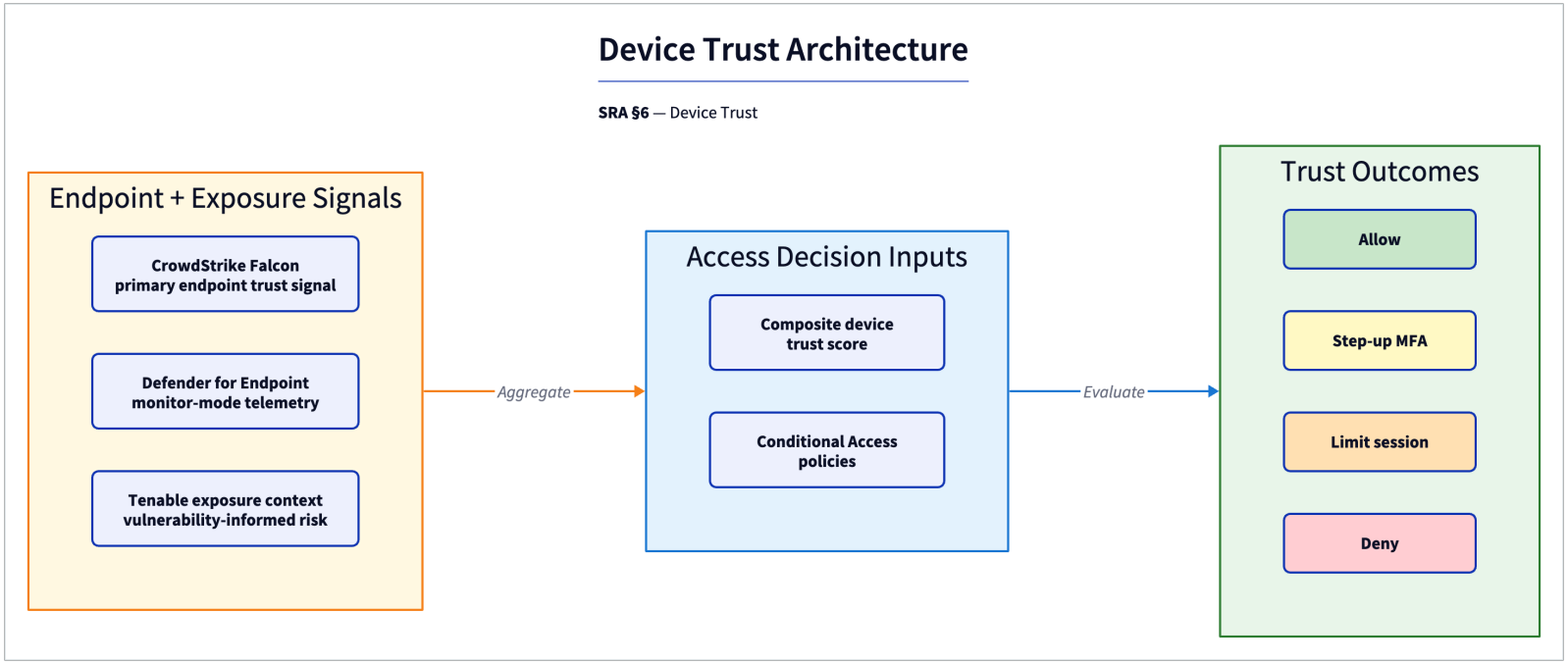


Figure 11: 10 Device Trust Architecture

7 Exposure and Posture (Tenable VM and CSPM)

NIST CSF 2.0 Alignment: ID.RA-01, DE.CM-02, PR.PS-04

- Tenable VM provides vulnerability identification across infrastructure and endpoints. Tenable.cs provides CSPM posture coverage and drift detection.

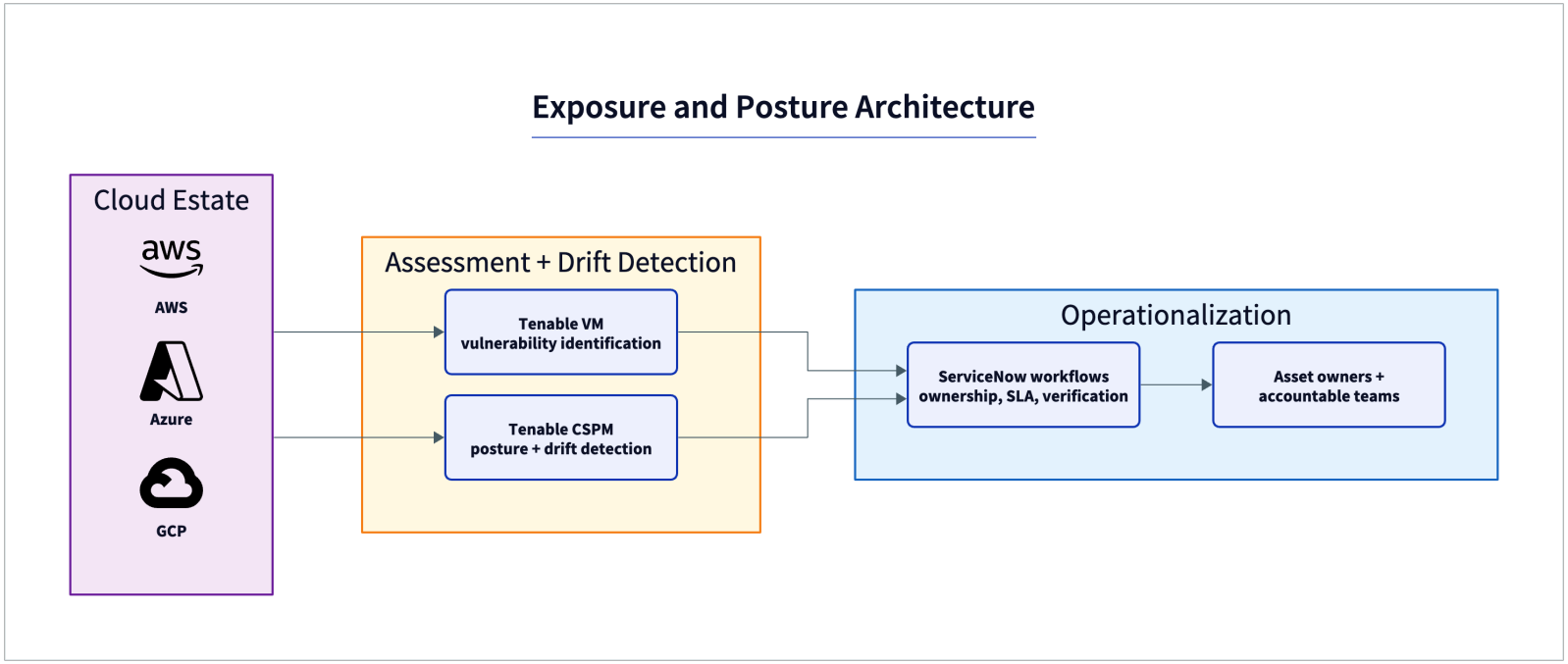


Figure 12: 11 Exposure And Posture Architecture

8 Application and API Trust (Sonatype, Burp Suite, Salt)

NIST CSF 2.0 Alignment: PR.DS-01, PR.PS-05, DE.CM-09

SOX §404 Relevance: SOX §404 PD-1 through PD-2 and CM-2 through CM-6: SDLC methodology, security testing in CI/CD, environment segregation, and change approval.

Gap — API Authentication Controls: The current architecture addresses application-layer testing (SAST/DAST/SCA) and future API behavioral analytics (Salt) but does not prescribe specific API authentication standards (e.g., OAuth 2.0/OIDC scoped tokens vs. static API keys). A formal API authentication standard should be developed under ISP 4.1 (PR.AA) to define acceptable mechanisms, token lifecycle management, and mutual-TLS requirements for service-to-service communication. The ASR Questionnaire (V4) now includes an API authentication assessment question to capture the current state per application. Additionally, SOX CM-1 (change management policy documentation) is referenced but the architecture does not prescribe a formal change management policy artefact. PD-3 (security testing sign-off) and PD-4 (system conversion testing) lack documented verification gates for security test acceptance and data-migration validation.

- Sonatype SCA manages dependency risk; Burp Suite DAST validates runtime security; Salt (future) provides API discovery and behavior analytics.

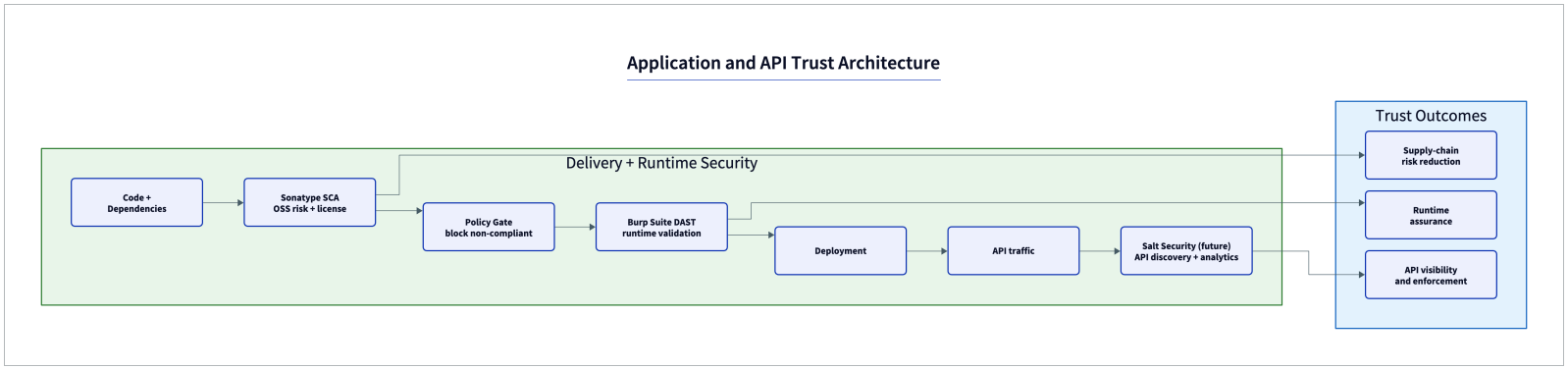


Figure 13: 12 Application And Api Trust Architecture

9 Operational Trust (ServiceNow SecOps, CMDB, Tagging)

NIST CSF 2.0 Alignment: DE.CM-06, RS.MA-01, RC.RP-01

SOX §404 Relevance: SOX §404 CO-1 through CO-4: job scheduling, backup/recovery, incident management, and batch processing integrity.

Gap — Operational Monitoring and Event Analysis: DE.CM-06 (external service provider activities monitored) is In Progress—ServiceNow integration with third-party telemetry feeds is not yet operational. SOX CO-1 (job scheduling) and CO-4 (batch processing integrity) lack specific ServiceNow automation evidence. The NIST CSF DE.AE (Adverse Event Analysis) function—covering DE.AE-02 through DE.AE-08—is entirely absent from the SRA subcategory mapping; correlation, enrichment, and escalation of security events require formal architectural treatment.

- ServiceNow SecOps is the central record for security incidents, vulnerability response, and evidence trails. CMDB and tagging enhance ownership and prioritization (future).

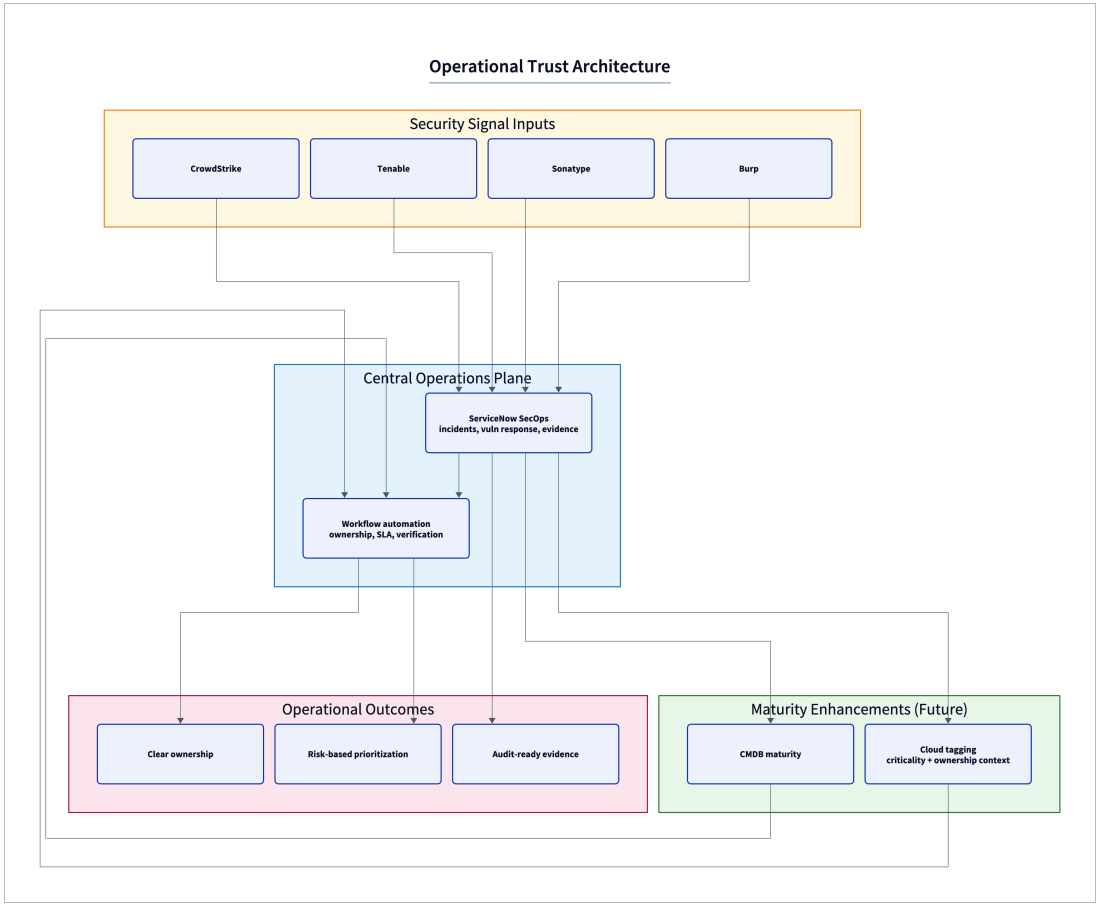


Figure 14: 13 Operational Trust Architecture

10 NIST CSF 2.0 Outcome Mapping

NIST CSF 2.0 Alignment: GV.OV-01, ID.RA-01, PR.AA-01, DE.CM-01, RS.MA-01, RC.RP-01

- NIST CSF 2.0 is used as the primary outcomes framework across Govern, Identify, Protect, Detect, Respond, and Recover.

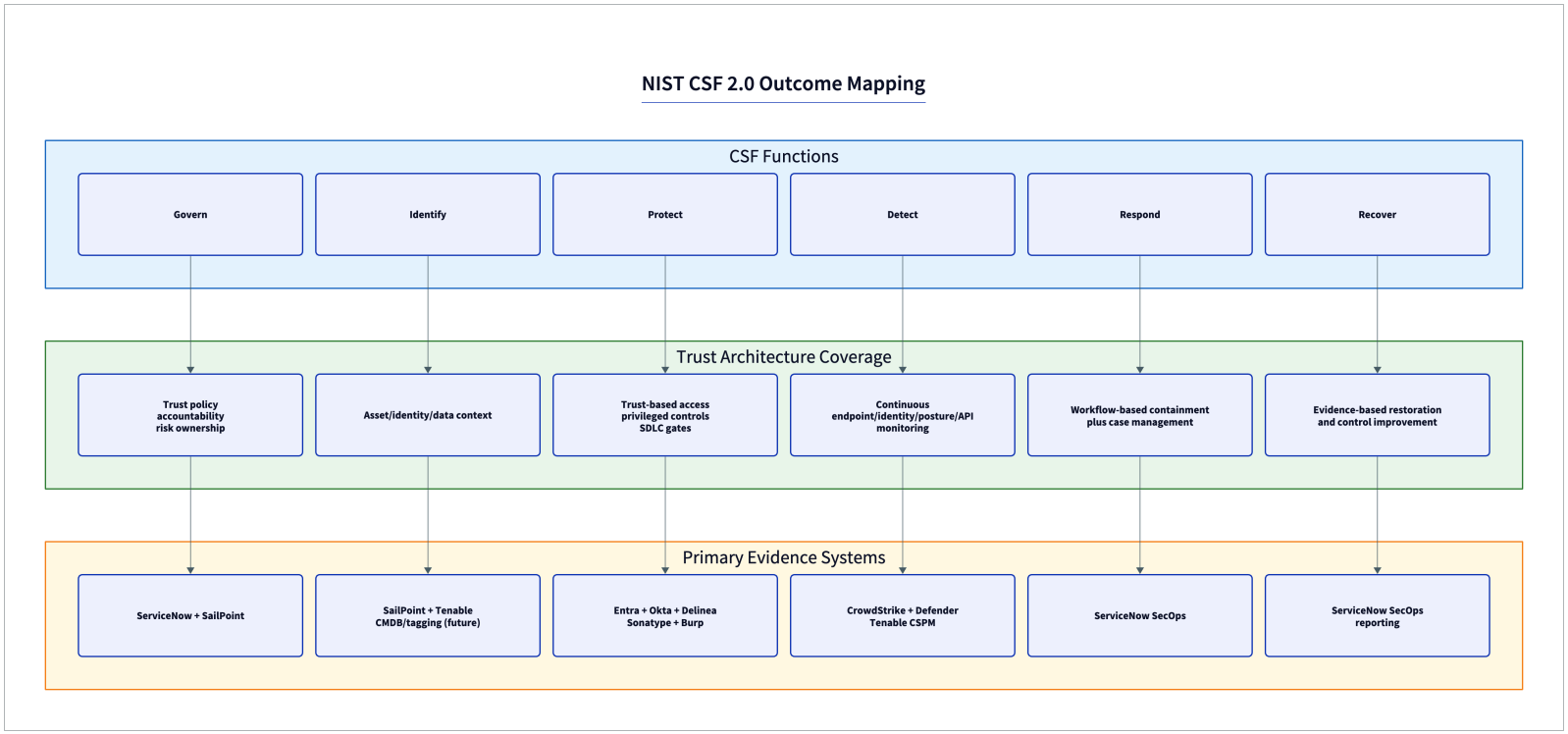


Figure 15: 14 Nist Csf Outcome Mapping

11 Implementation Roadmap

NIST CSF 2.0 Alignment: GV.SC-01, GV.RM-02

Gap — Supply Chain and Risk Appetite: GV.SC-01 (supply chain risk management program) is Planned and not yet initiated. GV.RM-02 (risk appetite and tolerance statements) is In Progress. Additional CSF subcategories GV.SC-02 through GV.SC-10—covering supplier due-diligence, contractual security requirements, supply chain integrity verification, and post-acquisition monitoring—are not mapped in the SRA. A formal third-party risk management program aligned to ISP 3.2 and NIST SP 800-161r1 should be established.

- Roadmap phases describe maturity sequencing across trust domains.

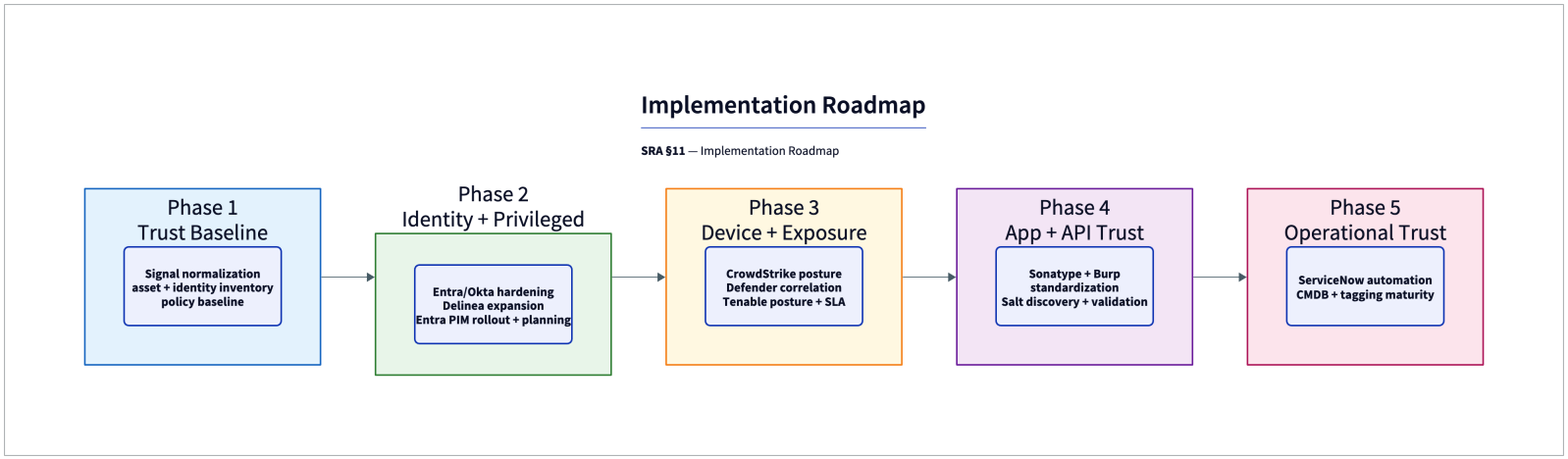


Figure 16: 15 Implementation Roadmap

12 Key Performance Indicators (KPIs)

NIST CSF 2.0 Alignment: GV.OV-02, DE.CM-09, RS.MA-04

- KPIs track adoption and effectiveness of trust controls (examples: MFA adoption, vuln SLAs, MTTD/MTTR).

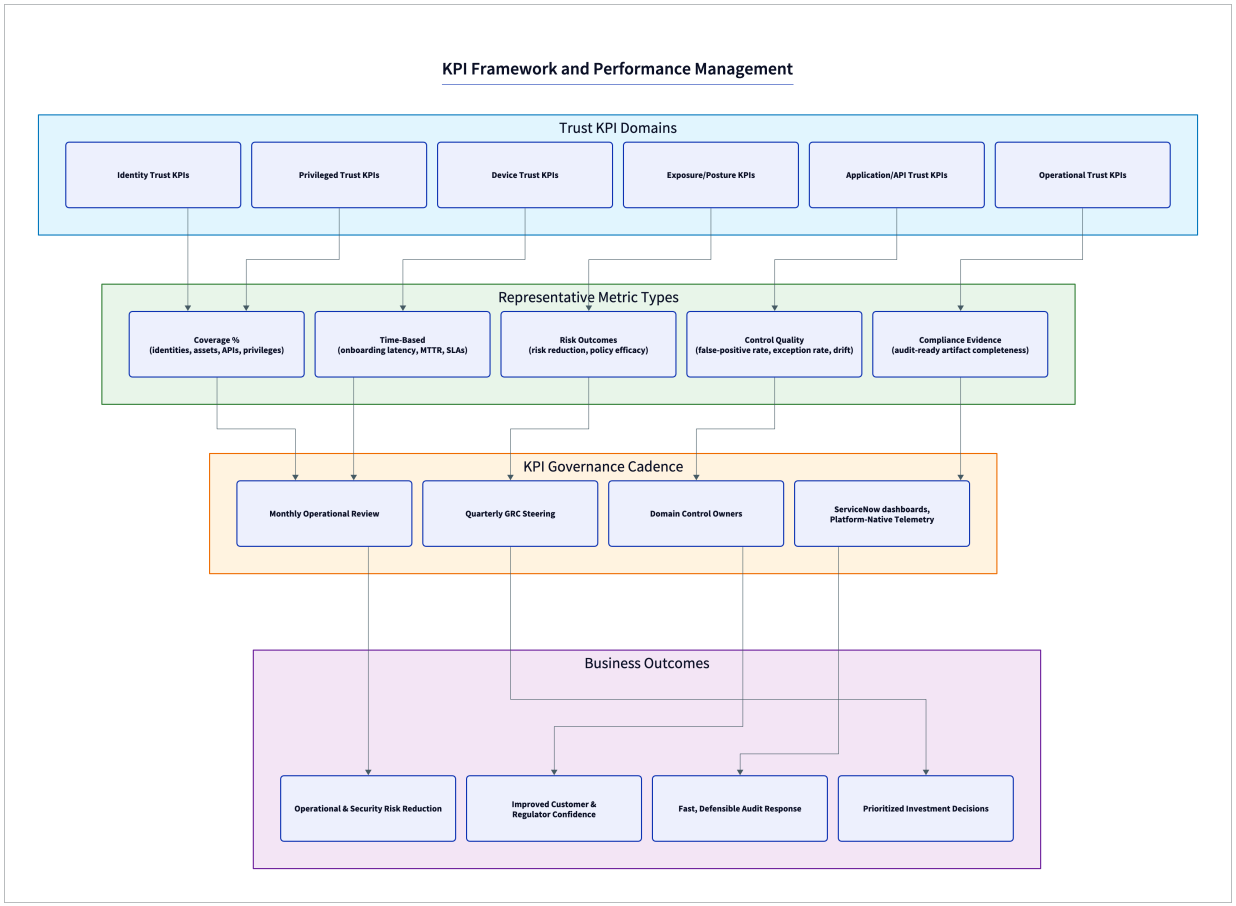


Figure 17: 17 Kpi Framework

13 Regulatory Compliance Alignment (SOX, FERPA)

NIST CSF 2.0 Alignment: GV.RM-03, GV.OV-03

FERPA Relevance: This section provides the comprehensive FERPA alignment matrix covering all applicable sections of 34 CFR Part 99.

SOX §404 Relevance: This section provides the comprehensive SOX §404 ITGC alignment matrix.

Gap — FERPA Coverage Gaps and Awareness Training: FERPA 34 CFR §§99.4 (student rights notification), 99.7 (annual FERPA notice requirements), 99.12 (limitations on re-disclosure), 99.33 (conditions on re-disclosure to third parties), and 99.37 (directory information opt-out procedures) lack specific architectural controls or evidence sources in the SRA. NIST CSF PR.AT (Awareness and Training) subcategories PR.AT-01 and PR.AT-02 are not addressed in the operational control architecture; a formal security awareness and role-based training program should be mapped.

- SOX: Access governance, change hygiene, and auditable evidence. FERPA: Protect education records via least privilege, governance, and auditable incident handling.

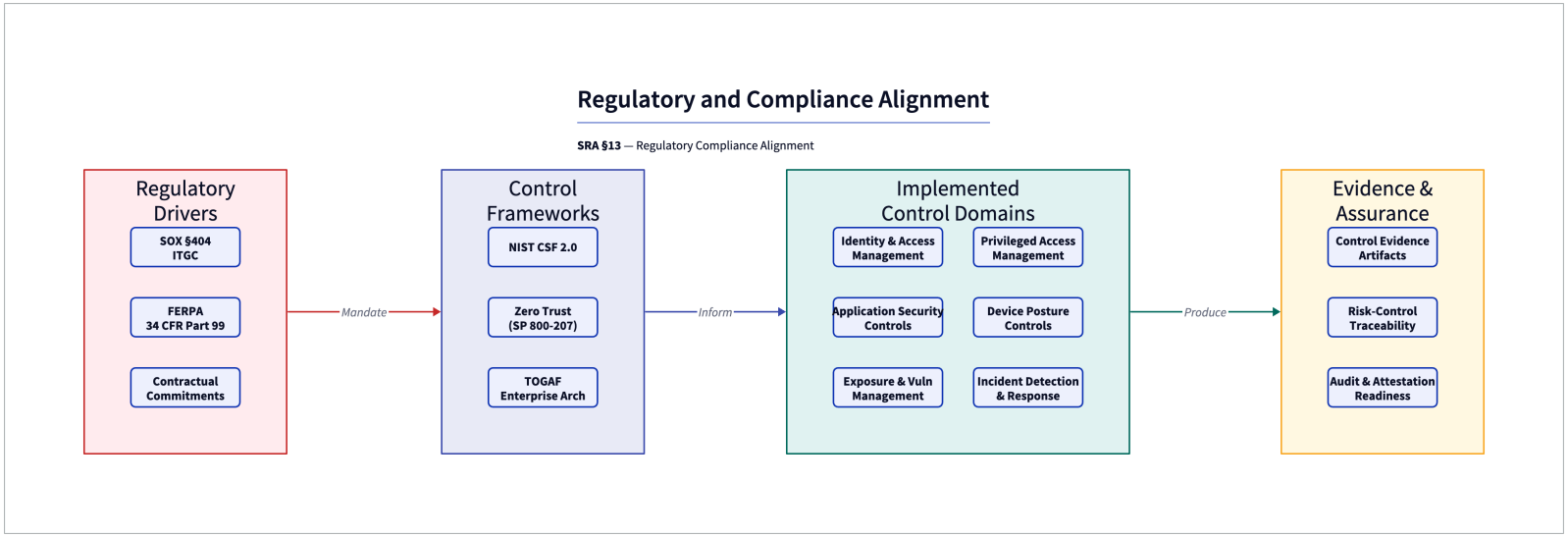
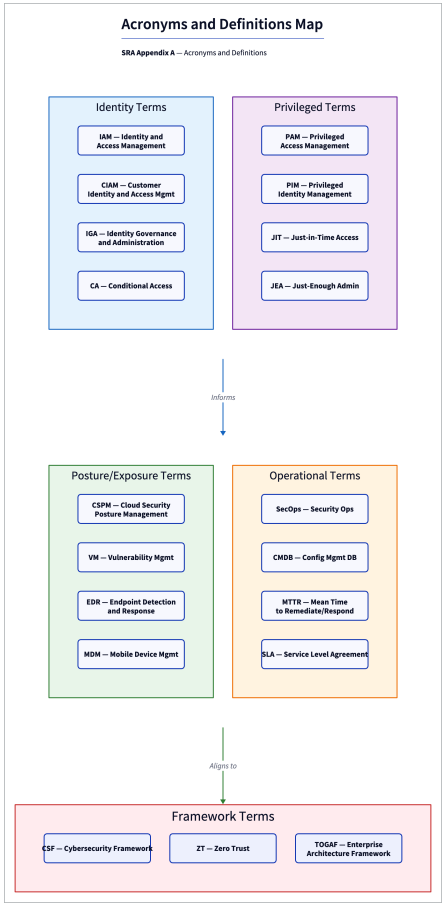


Figure 18: 18 Regulatory Compliance Alignment

A APPENDIX A — Acronyms and Definitions

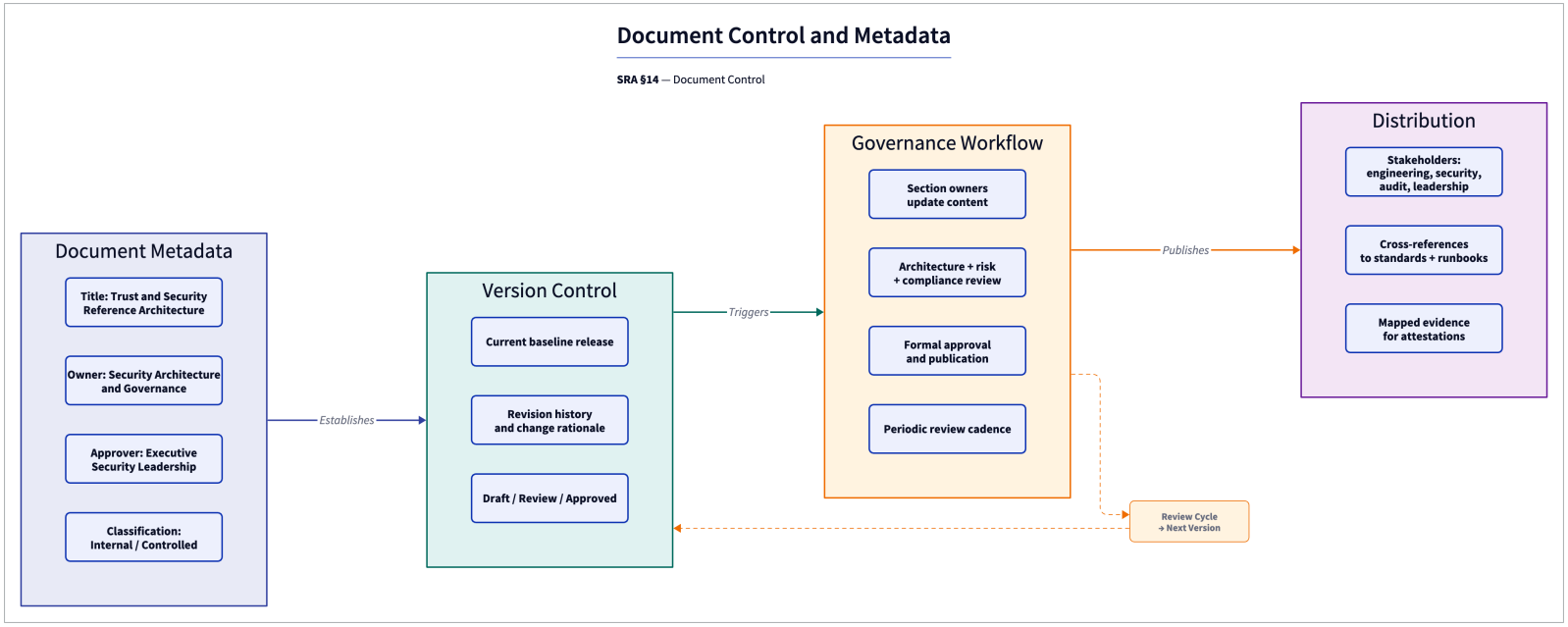


Term	Definition
CA	Conditional Access — policy-based access control in Microsoft Entra that evaluates signals (user, device, location, risk) to enforce authentication requirements.

Term	Definition
CIAM	Customer Identity and Access Management — IAM specifically for external/customer-facing authentication (e.g., Okta CIC for students and families).
CMDB	Configuration Management Database — central repository of IT asset records and relationships (ServiceNow CMDB).
CSF	Cybersecurity Framework — NIST framework (v2.0) organizing cybersecurity outcomes across Govern, Identify, Protect, Detect, Respond, and Recover functions.
CSPM	Cloud Security Posture Management — continuous monitoring of cloud configurations against security baselines (Tenable Cloud Security).
EDR	Endpoint Detection and Response — real-time endpoint monitoring and threat response (CrowdStrike Falcon).
FERPA	Family Educational Rights and Privacy Act — 34 CFR Part 99, protecting student education records.
FIDO2	Fast Identity Online 2 — passwordless authentication standard using hardware security keys or platform authenticators.
IAM	Identity and Access Management — policies and technologies ensuring the right individuals access the right resources at the right time.
IGA	Identity Governance and Administration — lifecycle management, access certification, and compliance reporting for identities.
ITGC	IT General Controls — SOX §404 controls over access, change management, computer operations, and program development.
JEA	Just-Enough Administration — restricting privileged sessions to the minimum set of commands required for the task.
JIT	Just-in-Time Access — time-bound privilege elevation that expires automatically (Entra PIM, Delinea).
MDM	Mobile Device Management — device enrollment, policy enforcement, and remote wipe capabilities.
MFA	Multi-Factor Authentication — requiring two or more verification factors for access.
MTTR	Mean Time to Remediate/Respond — average time between detection of a vulnerability or incident and its resolution.
NIST	National Institute of Standards and Technology — U.S. federal agency publishing cybersecurity standards and guidelines.
PAM	Privileged Access Management — controls for discovering, managing, and auditing privileged accounts and sessions (Delinea).
PIM	Privileged Identity Management — role-based JIT elevation with approval workflows (Microsoft Entra PIM).
RBAC	Role-Based Access Control — access permissions assigned by organizational role rat her than individual identity.

Term	Definition
SecOps	Security Operations — the team and processes for monitoring, detecting, and responding to security events.
SLA	Service Level Agreement — formal commitment on service availability, response time, or remediation timelines.
SOX	Sarbanes-Oxley Act — U.S. legislation requiring internal controls over financial reporting (§404).
SRA	Security Reference Architecture — this document; the enterprise trust and security architecture blueprint.
TOGAF	The Open Group Architecture Framework — enterprise architecture methodology used for platform and security architecture alignment.
VM	Vulnerability Management — continuous process of identifying, classifying, prioritizing, and remediating vulnerabilities (Tenable).
WHfB	Windows Hello for Business — passwordless, certificate-based authentication using biometrics or PIN bound to a device.
ZT	Zero Trust — security model requiring continuous verification of every user, device, and transaction regardless of network location (NIST SP 800-207).

B APPENDIX B — Document Control



Attribute	Value
Document Title	Stride Security Reference Architecture
Version	7.0
Date	March 3, 2026
Classification	Confidential
Author	Security Architecture / GRC
Supersedes	SRA V6 (February 27, 2026)

Version	Date	Change Description
V6.0	February 27, 2026	Initial trust security architecture; 22 D2 diagrams; NIST CSF 2.0 alignment.
V7.0	March 3, 2026	Enhanced appendices (A–E); per-section FERPA/SOX alignment; gap annotations; consolidated gap register; diagram routing improvements; acronym and definitions table; NIST CSF and evidence traceability appendices.

C APPENDIX C — NIST CSF 2.0 Mapping and Implementation Status

This appendix maps NIST Cybersecurity Framework 2.0 subcategories referenced in this SRA to the corresponding architecture sections and their current implementation status.

CSF Subcategory	Outcome Description	SRA Section	Status
GV.OC-01	Organizational context for cybersecurity risk management	§1 Executive Summary	Implemented
GV.RM-01	Risk management objectives established and communicated	§1 Executive Summary	Implemented
GV.RM-02	Risk appetite and tolerance statements defined	§11 Implementation Roadmap	In Progress
GV.RM-03	Risk management activities integrated across enterprise	§13 Regulatory Compliance	Implemented
GV.OV-01	Cybersecurity strategy outcomes assessed	§1, §10 NIST CSF Mapping	Implemented
GV.OV-02	Cybersecurity performance evaluated against KPIs	§12 KPIs	Implemented
GV.OV-03	Regulatory requirements integrated into governance	§13 Regulatory Compliance	Implemented
GV.PO-01	Cybersecurity policy established and communicated	§2 Architecture Overview	Implemented
GV.SC-01	Supply chain risk management program established	§11 Implementation Roadmap	Planned
ID.AM-01	Asset inventories maintained	§3 Personas and Trust Boundaries	Implemented
ID.RA-01	Vulnerabilities identified, validated, and recorded	§7 Exposure and Posture, §10	Implemented
PR.AA-01	Identities and credentials managed	§4 Identity and Access	Implemented
PR.AA-02	Identity proofing and binding to credentials	§4 Identity and Access	Implemented
PR.AA-03	Users, services, and hardware authenticated	§3, §4 Identity and Access	Implemented
PR.AA-05	Least privilege and separation of duties enforced	§5 Privileged Trust	Implemented
PR.DS-01	Data-at-rest and data-in-transit protected	§8 Application and API Trust	Implemented

CSF Subcategory	Outcome Description	SRA Section	Status
PR.PS-01	Configuration baselines maintained	§2, §4 Architecture Overview	Implemented
PR.PS-02	Software maintained and replaced per policy	§5 Privileged Trust	Implemented
PR.PS-03	Hardware maintained and replaced per policy	§6 Device Trust	Implemented
PR.PS-04	Log integrity and availability ensured	§7 Exposure and Posture	Implemented
PR.PS-05	Installation and execution of unauthorized software prevented	§8 Application and API	In Progress
DE.CM-01	Networks monitored for anomalies and attacks	§6 Device Trust	Implemented
DE.CM-02	Physical environment monitored for anomalies	§7 Exposure and Posture	Implemented
DE.CM-03	Personnel activity monitored for anomalies	§5 Privileged Trust	Implemented
DE.CM-06	External service provider activities monitored	§9 Operational Trust	In Progress
DE.CM-09	Computing hardware and software monitored	§8, §12 KPIs	Implemented
RS.MA-01	Incident response plan executed	§9 Operational Trust	Implemented
RS.MA-04	Incident response performance evaluated	§12 KPIs	Implemented
RC.RP-01	Recovery plan executed during/after incident	§9 Operational Trust	Implemented

Status definitions: Implemented = controls active and evidenced; In Progress = controls partially deployed or in current roadmap phase; Planned = controls identified but not yet initiated.

D APPENDIX D — Evidence Traceability Matrix

This appendix identifies the primary evidence artifacts for each NIST CSF 2.0 subcategory, supporting audit readiness and attestation preparation.

CSF Subcategory	Evidence Artifacts	Evidence Owner
GV.OC-01	SRA document, governance charter	Security Architecture
GV.RM-01	Risk register, risk appetite statement	GRC / Risk Management
GV.OV-01	CSF outcome mapping (§10), annual review records	Security Architecture
GV.OV-02	KPI dashboard (§12), quarterly metrics reports	Security Operations
GV.PO-01	ISP 1.0–12.0 policy library, IISP 2.0	Information Security
ID.AM-01	ServiceNow CMDB asset inventory, Entra directory	IT Operations
ID.RA-01	Tenable scan reports, risk assessment records	Vulnerability Management
PR.AA-01	Entra ID configurations, Okta CIC tenant configs	Identity Engineering
PR.AA-02	FIDO2 key enrollment records, MFA registration logs	Identity Engineering
PR.AA-03	Conditional Access policy exports, sign-in logs	Identity Engineering
PR.AA-05	Delinea session recordings, PIM activation logs	Privileged Access Mgmt
PR.DS-01	TLS configurations, encryption-at-rest settings	Application Security
PR.PS-01	CIS benchmark scan results, baseline configs	Infrastructure Security
PR.PS-03	CrowdStrike sensor deployment reports, Defender status	Endpoint Security
PR.PS-05	Sonatype policy results, application allowlists	Application Security
DE.CM-01	CrowdStrike detection logs, network alert reports	Security Operations
DE.CM-03	PIM audit logs, privileged session recordings	Security Operations
DE.CM-09	Burp Suite scan reports, Salt Security API findings	Application Security
RS.MA-01	ServiceNow incident records, runbook executions	Incident Response
RS.MA-04	MTTR reports, incident post-mortem records	Incident Response
RC.RP-01	Recovery test results, backup verification logs	Business Continuity

Evidence sources should be aligned to the formal control library and refreshed during each assessment cycle. Artifacts are referenced in the control mapping tables throughout this SRA.

E APPENDIX E — Consolidated Gap Register

This appendix consolidates all identified gaps across NIST CSF 2.0 subcategory coverage, FERPA regulatory requirements, and SOX §404 ITGC controls. Each gap references the SRA section where the deficiency is annotated and includes a priority for remediation planning.

Gap ID	CSF / Regulatory Ref	SRA §	Description	Priority
GAP-01	PR.AA-04, PR.AA-06	§4	FERPA §99.30/§99.35 consent and disclosure controls lack explicit architectural enforcement; PR.AA-04 and PR.AA-06 unmapped.	High
GAP-02	PR.AA (API)	§8	No formal API authentication standard (OAuth 2.0/OIDC vs. static keys); mutual-TLS and token lifecycle undefined.	High
GAP-03	CM-1, PD-3, PD-4	§8	SOX CM-1 change management policy artefact not prescribed; PD-3/PD-4 security testing sign-off and conversion validation gates missing.	Medium
GAP-04	DE.CM-06	§9	External service provider monitoring In Progress — ServiceNow integration with third-party telemetry not yet operational.	High
GAP-05	CO-1, CO-4	§9	SOX CO-1 (job scheduling) and CO-4 (batch processing integrity) lack specific ServiceNow automation evidence.	Medium
GAP-06	DE.AE-02–08	§9	Entire DE.AE (Adverse Event Analysis) function absent from SRA mapping; event correlation, enrichment, and escalation unaddressed.	High
GAP-07	GV.SC-01	§11	Supply chain risk management program Planned but not initiated.	High
GAP-08	GV.RM-02	§11	Risk appetite and tolerance statements In Progress.	Medium
GAP-09	GV.SC-02–10	§11	Supplier due-diligence, contractual security, supply chain integrity, and post-acquisition monitoring subcategories unmapped.	High

Gap ID	CSF / Regulatory Ref	SRA §	Description	Priority
GAP-10	§99.4, §99.7, §99.12, §99.33, §99.37	§13	Five FERPA sections lack specific architectural controls or evidence sources in the SRA.	High
GAP-11	PR.AT-01, PR.AT-02	§13	Awareness and Training subcategories not addressed in operational control architecture.	Medium
GAP-12	PR.PS-05	§8	Unauthorized software prevention In Progress — Sonatype policy enforcement not fully deployed.	Medium
GAP-13	GV.RM, PR.AT, DE.AE	ASR	ASR questionnaire lacks questions covering risk management governance, awareness training, and adverse event analysis domains.	High

Gaps are derived from the comprehensive control-target analysis performed in March 2026 comparing NIST CSF 2.0 (100 subcategories), FERPA 34 CFR Part 99 (18 sections), and SOX §404 ITGC (19 controls) against the SRA and ASR questionnaire coverage. Priority reflects the assessed impact on audit readiness and regulatory compliance.